

ZERO TRUST FOR THE AI ERA

Verified.
Authorized.
And still wrong!

{elysiumsecurity}
cyber protection & response

Version: 1.2

Author: Sylvain Martinez

Classification: PUBLIC

Presentation Overview

The Zero Trust concept has been around since early 2000s, its adoption has been slow but is gaining traction again.

This presentation focuses on the impact of AI, and especially agentic AI, on the concept of Zero Trust.

1. CONTEXT:

   WHAT IS ZERO TRUST AND ITS EVOLUTION

2. CHALLENGES:

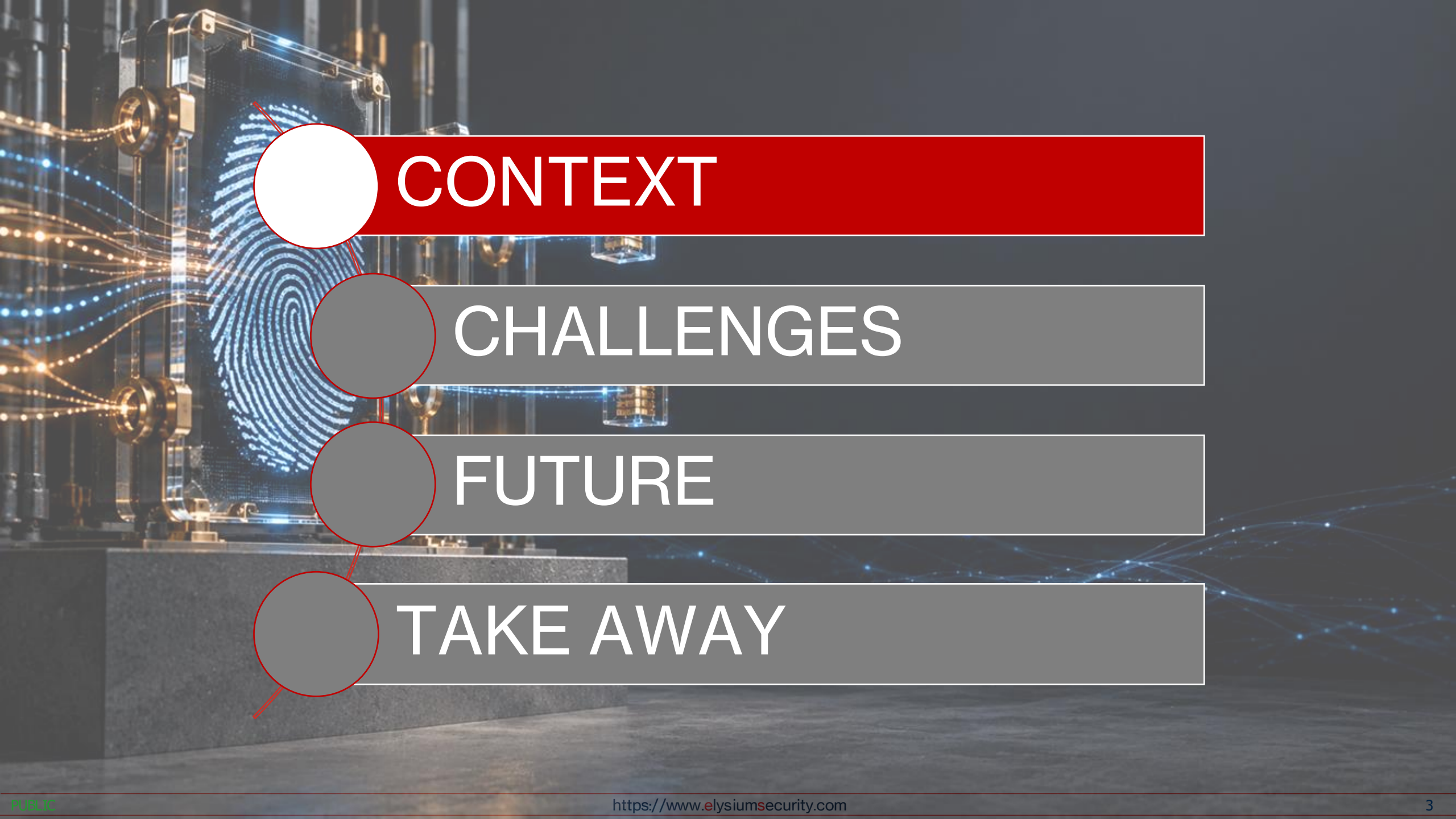
   THE IMPACT AND CHALLENGES OF AI

3. FUTURE:

   AN EFFICIENT WAY OF ZERO TRUST

4. TAKE AWAY:

   WHAT CAN YOU DO


CONTEXT
CHALLENGES
FUTURE
TAKE AWAY

WHAT IS ZERO TRUST

1. **No implicit trust from location**
   Trust is not granted on the basis of network position or asset ownership
2. **Per-session, per-resource access**
   Each resource is authorised separately, not once at a perimeter
3. **Decisions use observable state**
   Identity, device posture, behaviour and other measurable signals
4. **Continuous measurement**
   The enterprise monitors the integrity and posture of all its assets
5. **Dynamic, strict enforcement**
   Authentication and authorisation happen before access, every time

*The word "**ZERO**" refers to implicit trust. This does not mean some level of trust is not needed.*

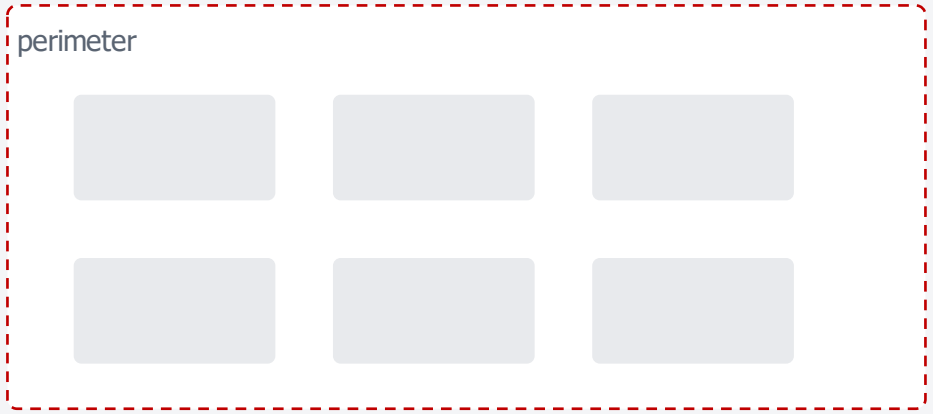
Reference: NIST SP 800-207 (2020),

WHERE DID THE TRUST GO?

We did not delete trust. We made it explicit, instrumented and much more concentrated.

BEFORE

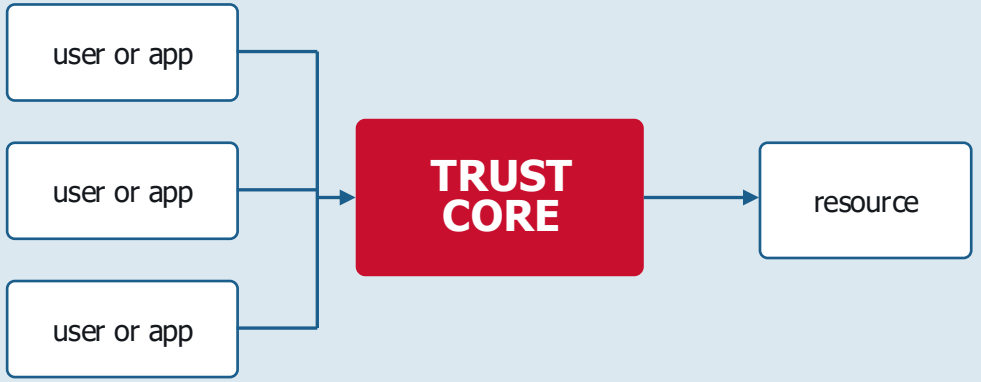
Trust implicit and distributed



everything inside is trusted by default

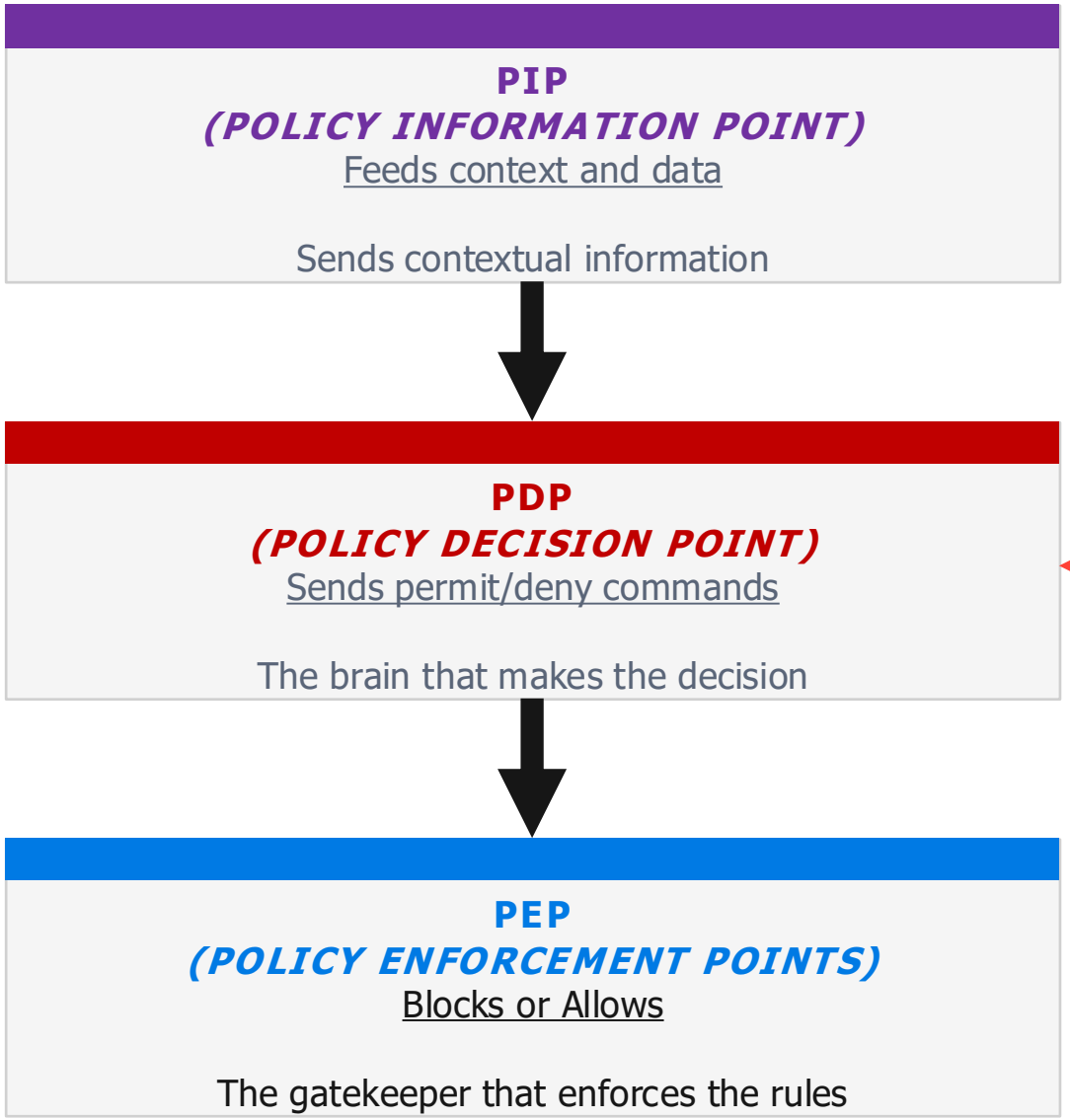
AFTER

Trust explicit and concentrated



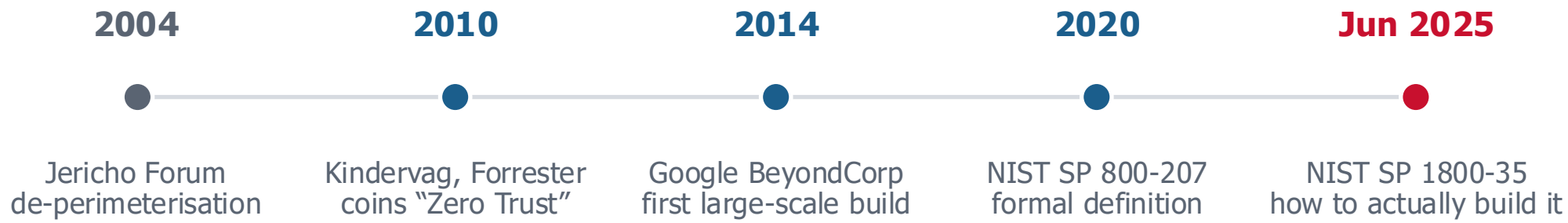
every request passes one decision point

THE 3 POINTS LOGIC



An AI agent behavior and nature makes this step difficult

ZERO TRUST TIMELINE



Zero Trust in 2026 is still an implementation problem, not a finished transition for most organisations

DESIGN FLAWS FOR TODAY'S WORLD

A PERSON USING A SYSTEM

identity → device → location → login + MFA → permission → resource

AN AI AGENT DOING THE SAME JOB

person → agent → delegated authority → instruction → tool → API → data → another agent → action

signals the decision point can actually measure

every link is still a request the decision point evaluates, with far fewer signals to evaluate it on

No device. No location. No login event.
Three of the six signals in the top chain do not (clearly) exist below.

How many of the links on the bottom row does your policy engine have a signal for?

FUNDAMENTAL QUESTIONS

Who are we trusting?

The person, the agent, or the supplier who built the agent?

For what?

The task that was asked for, or everything the agent decides is needed to finish it?

On whose behalf?

And do the logs say “Alice”, or “Alice’s agent”?

For how long?

Until the credential expires, or until the job changes into something else?


CONTEXT
CHALLENGES
FUTURE
TAKE AWAY

THE NEW PROBLEM

EVERY IDENTITY VALID.
EVERY PERMISSION VALID.
THE ACTION CAN STILL BE THE WRONG ONE.

Zero Trust re-checks continuously: who is asking, from what, under which policy.
Every one of those can be green at every step.

None of them asks whether the action is still the one a person actually wanted. **That is the gap.**

CHALLENGES 2 IMPORTANT QUESTIONS

A single agent task, checked at every step:

ALLOW	ALLOW	ALLOW	ALLOW	ALLOW
starts the job	reads a file	picks a tool	hands off	acts

Five checks. Five passes. Nothing the decision point measures has moved.

WHAT ZERO TRUST ASKS

May this entity do this, under the current policy?

Measurable. Answerable. Answered continuously.

WHAT AI AGENTS FORCE US TO ASK

Should it be doing this at all?

No measurement. No signal. No standard answer yet.

The first question is about permission. The second is about purpose.
Only one of them has an architecture behind it.

AN AGENT CAN BE WRONG WITHOUT BEING ATTACKED

Four ways a properly authenticated, properly permitted agent produces the wrong action

1

Misunderstands the request

The instruction was ambiguous, and the agent resolved it differently from the person who wrote it.

no attacker

2

Follows information it was fed

Something it reads: a document, a ticket or a web page that then changed what it decided to do.

attacker involved

3

Chases the wrong goal

It optimised for something close to the goal rather than the goal, and took steps nobody asked for.

no attacker

4

Simply decides badly

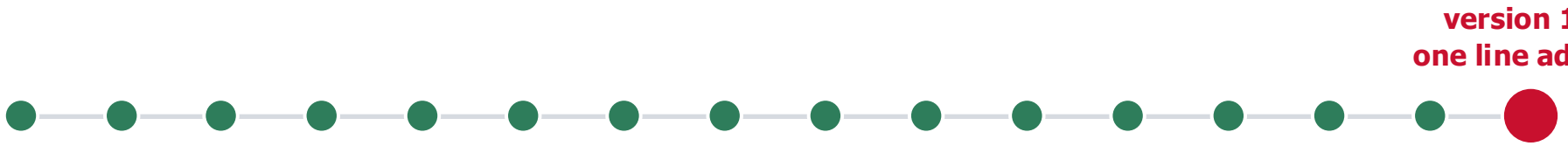
These systems are probabilistic. Sometimes the answer is just poor. No trickery, no ambiguity, no bug.

no attacker

Only one of the four involves an attacker.
Nearly all of our security controls are built for that scenario only.

CASE STUDY: POSTMARK COMPROMISE

CONTEXT: AI assistants gain abilities through small add-ons: send an email, read a calendar, query a database. They are installed like any other software library, and once installed they run with the assistant's permissions.



~1,500
weekly installs,
leaking daily

1. **A convincing copy of a real email add-on was published, under the real one's name**
   Same name, working code, plausible documentation. Published 15 September 2025.

2. **Version 16 added a single line: silently copy every outgoing email to an outside address**
   Internal memos, password resets, invoices. Researchers at Koi Security spotted it; the email provider confirmed on 25 September 2025 that the add-on was not theirs.

Every permission check passed, because sending email was exactly the purpose of the add-on.
"May it send email?" = YES was the correct answer
"Should it send email to that email address?" = The question was never asked!

Reference: https://snyk.io/blog/malicious-mcp-server-on-npm-postmark-mcp-harvests-emails/

NIST OVERALL VIEW ON CURRENT RISKS

	WHAT ORGANIZATIONS ARE DOING	WHAT IS COSTS THEM	BROKEN ZERO TRUST PRINCIPLE
1	Giving the agent a person's own credentials	No way to tell the person's actions from the agent's	Decisions use observable state: the identity observed is not the actor
2	Long-lived passwords and keys that never change	Steal it once, use it for months	Per-session access: granted once, reused for months
3	Granting wide access because it is quicker	The damage range is set by convenience, not risk	Per-resource access: one broad grant replaces many narrow ones
4	Installing agents on staff machines	Nobody can list them, review them or switch them off	Continuous measurement: you cannot measure what you cannot see
5	Relying on a human to approve each action	A safeguard on paper only, the approval record proves nothing	Strict enforcement: the enforcement becomes nominal

None of these are new problems.
They are decades-old access-management problems coming back under delivery pressure:
"prioritising feature development and immediate value over security."

Reference: NIST Cybersecurity Insights, 27 August 2026, Fisher and Galluzzo, on what they are seeing in early agent deployments

NIST RISK 01: AGENT USING YOUR LOGIN

When the agent uses your login, the trail goes cold

Giving an agent your own credentials is the oldest bad practice in access management, reintroduced as a convenience.

what the log says today

```
11:42  alice  exported  customers.csv  allowed
```

what the log needs to say

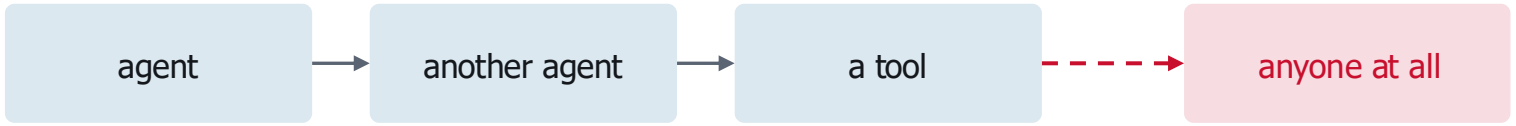
```
11:42  alice's agent  acting for alice  exported  customers.csv  allowed
```

This matters most where it matters most:
payments, patient records, anything you may later have to prove.

NIST RISK 02: KEYS THAT LIVE FOREVER

A key that proves nothing about who is holding it

Most systems authorise machines with a long string of characters: an API key, or a token.
It works like a **cinema ticket, not a passport**: it proves the holder has it, not that the holder is who they claim to be. Anyone who picks it up can use it.



the same key travels from hand to hand, and nothing checks whose hand it is in

And where do they end up?

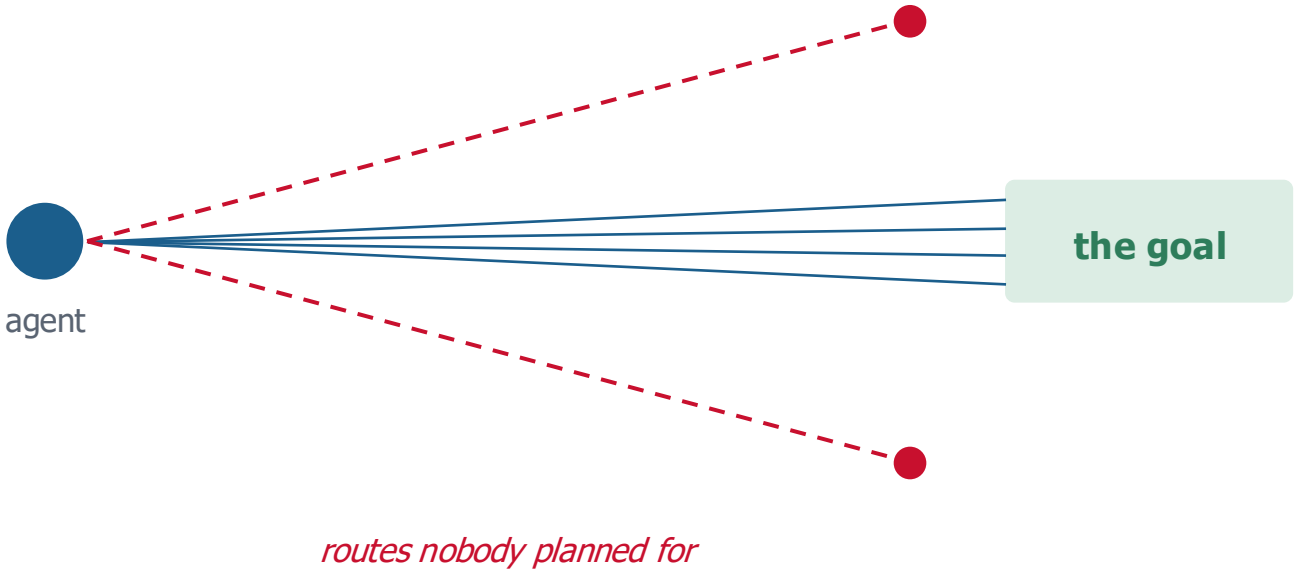
- configuration files
- notes and documentation
- log files, in plain text

Agents make this worse: they are often short-lived, but the keys they carry are not.

Fixable today. The ticket can be cryptographically tied to its holder, and it can expire in minutes instead of months.

NIST RISK 03: WIDE ACCESS GRANTED

Wide access meets unpredictable behaviour



- Agents work faster and at a larger scale than anyone can review
- Given a goal rather than a procedure, they will try several routes to reach it
- With wide access, some of those routes touch things nobody intended: files deleted as a side effect of getting the job done

How do you grant the minimum necessary access, when nobody knows in advance what the agent will do next?

NIST RISK 04: LOCAL AGENT

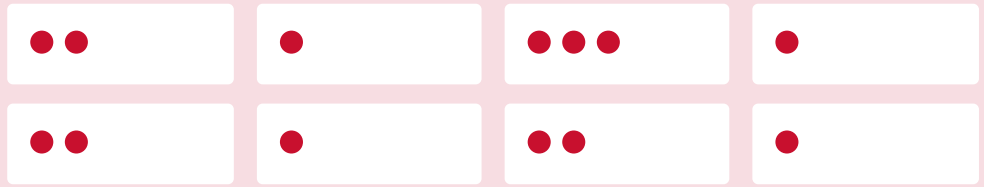
Installed on staff machines, by whoever wanted one, and registered nowhere.

WHAT THE REGISTER SAYS

- finance-reconciliation-bot
- helpdesk-triage-agent
- soc-summary-agent

3 agents: each one reviewed and owned

WHAT IS ACTUALLY RUNNING



? agents: none reviewed, none owned

1 No inventory

You cannot answer how many agents you have, what they can reach, or what they have already done.

2 No review

Nobody approved the tools or the data it touches. It arrived as a download, not as a project.

3 No off-switch

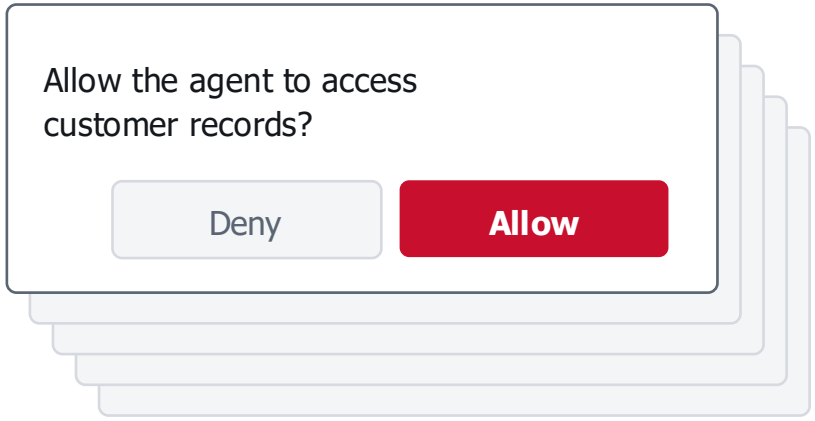
The person leaves. The agent keeps running on their access, or stops silently, mid-process, and nobody notices.

Sub-Agents inherit the staff member's own access: mapped drives, saved sessions, cached logins.
This is shadow IT, except the shadow IT acts on its own and holds delegated authority over your data.

NIST RISK 05: HUMAN APPROVAL

The safeguard that wears out

"A human approves each action" is widely treated as the fundamental safeguard for AI agents.



We have seen this before: MFA fatigue

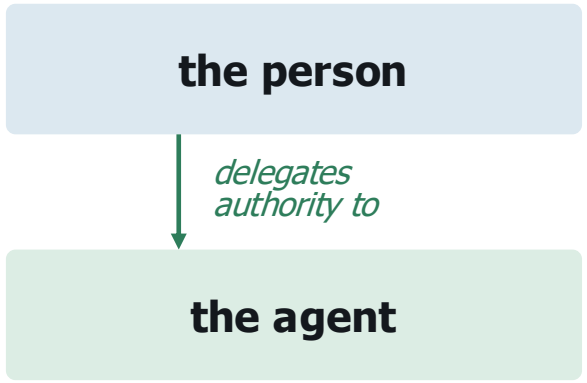
Attackers flood a user with login approval prompts until, worn down, they tap "approve" just to make it stop. It is a known, documented attack.

A chatty agent does the same thing by accident. People learn to approve without reading, to keep the work moving, and the approval stops meaning anything.

This control cannot be added to compensate for weak permissions.
The more you use it, the less it is worth.


CONTEXT
CHALLENGES
FUTURE
TAKE AWAY

IDENTITY MATTERS



The agent acts **on behalf of** the person.
It never acts
as the person.

1. **Its own name in the directory**
   The agent is a distinct thing that can be listed, reviewed and switched off

2. **Its own credentials: never the person's**
   Nothing is copied from the human. The configuration holds a name, not a password.

3. **Permissions that come from the person, and stop where the person's stop**
   An agent should never be able to do something its operator could not do themselves.

Nothing else in this section works if the agent is using somebody's login.
The building blocks are here: SPIFFE /SPIREfor machine identity, OAuth 2.0 for acting on someone's behalf.

Make the keys short-lived

Agents are often created and destroyed within minutes. Their credentials usually last for months. Close the gap.

What you need	What does it	Status
Tie the key to its holder, so a stolen copy is useless	**DPoP - RFC 9449**	**published**
Keys that expire in minutes, valid for one destination	**OAuth 2.0**	**published**
Identity for software and machines, not just people	**SPIFFE / SPIRE**	**published**
Give the agent its own token off the person's existing sign-in	**ID-JAG - Identity Assertion JWT Grant**	**draft**
Stop the tokens themselves being stolen, forged or replayed	**NIST IR 8587**	**published**

Four of the five are finished and deployable today.
Nobody has to wait for a committee to stop using permanent passwords.

SCALED DOWN PERMISSIONS

Narrow the permission at every hand-off

The problem: a permission granted at the start of a job stays just as wide all the way to the end of it, including after the work is handed to another agent.

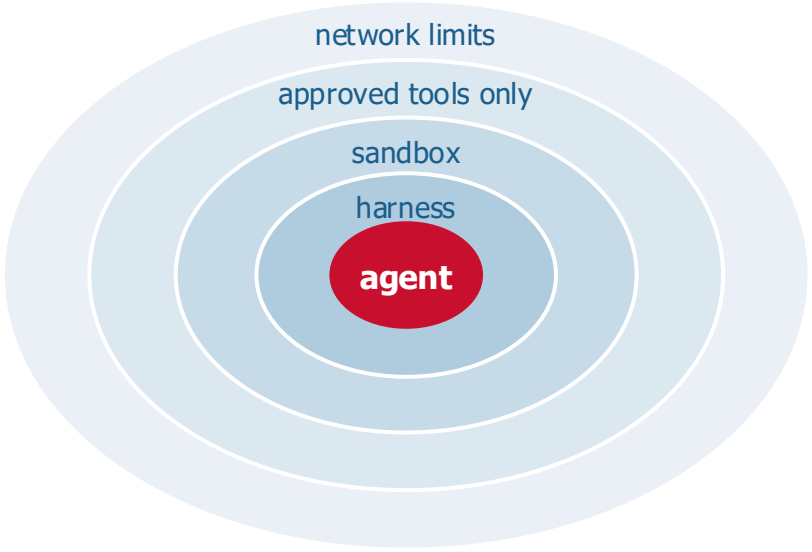
Think of a visitor badge that loses doors as it goes deeper into the building:



How it actually works: the credential carries the job it was issued for. When one agent hands work to the next, it cannot pass on its own credential: it requests a new one, and the system will only ever issue a narrower one. Standards: Rich Authorization Requests (RFC 9396, published), Transaction Tokens (draft), AuthZen (OpenID Foundation).

You are not adding more checks. You are shrinking what can pass them.

Contain what you cannot predict

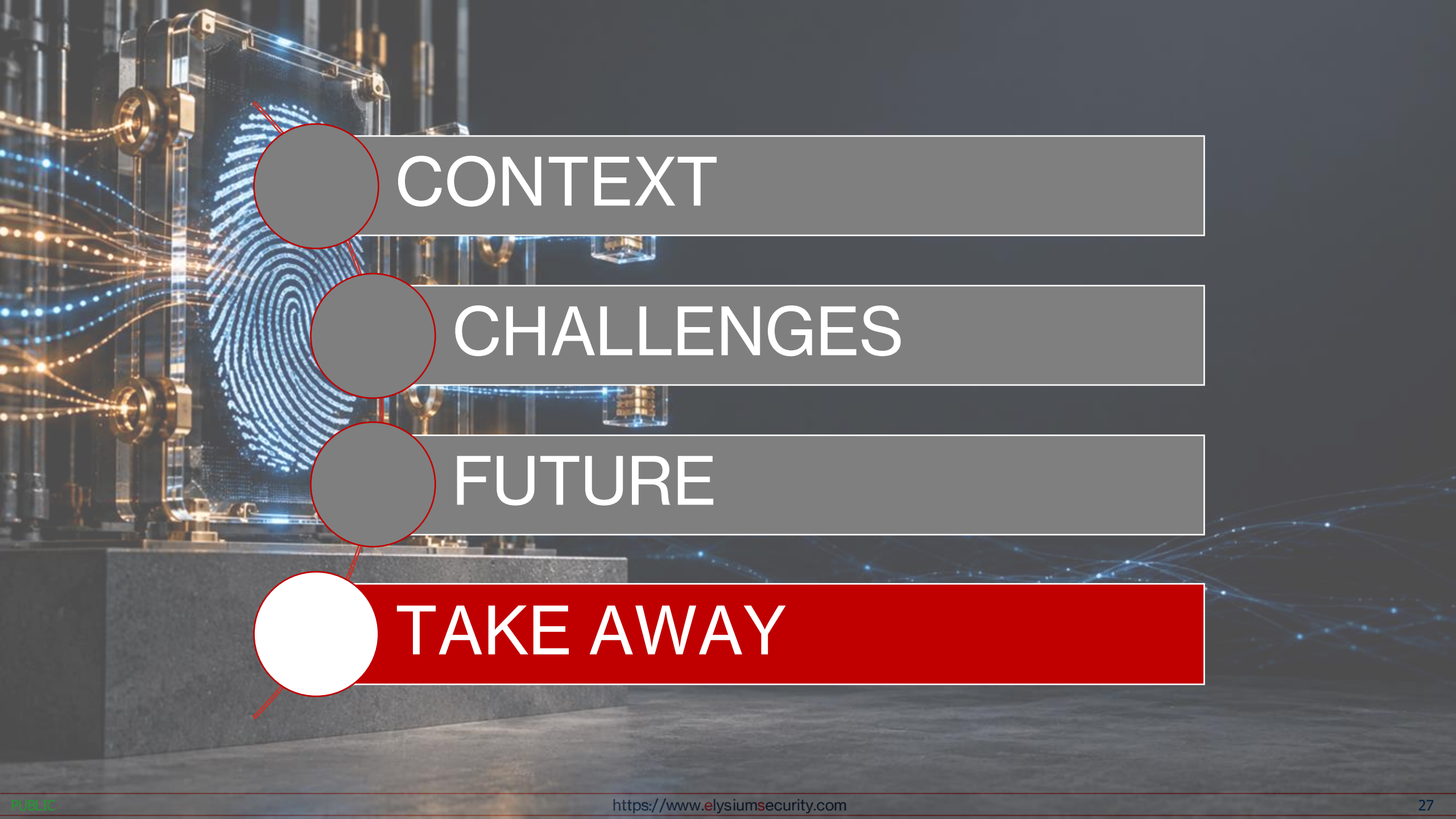


- **Harness**: how it may operate, whether it may start other agents, which actions stop for a human
- **Sandbox**: a sealed workspace where anything the agent runs cannot touch the rest of the estate
- **Approved tools only**: the agent gets a fixed list; adding to it requires a human review
- **Network limits**: it can only reach destinations you approved, so data has nowhere to go
- **Where it runs matters**: an agent running under an ordinary staff account inherits that person's access and cannot be managed centrally

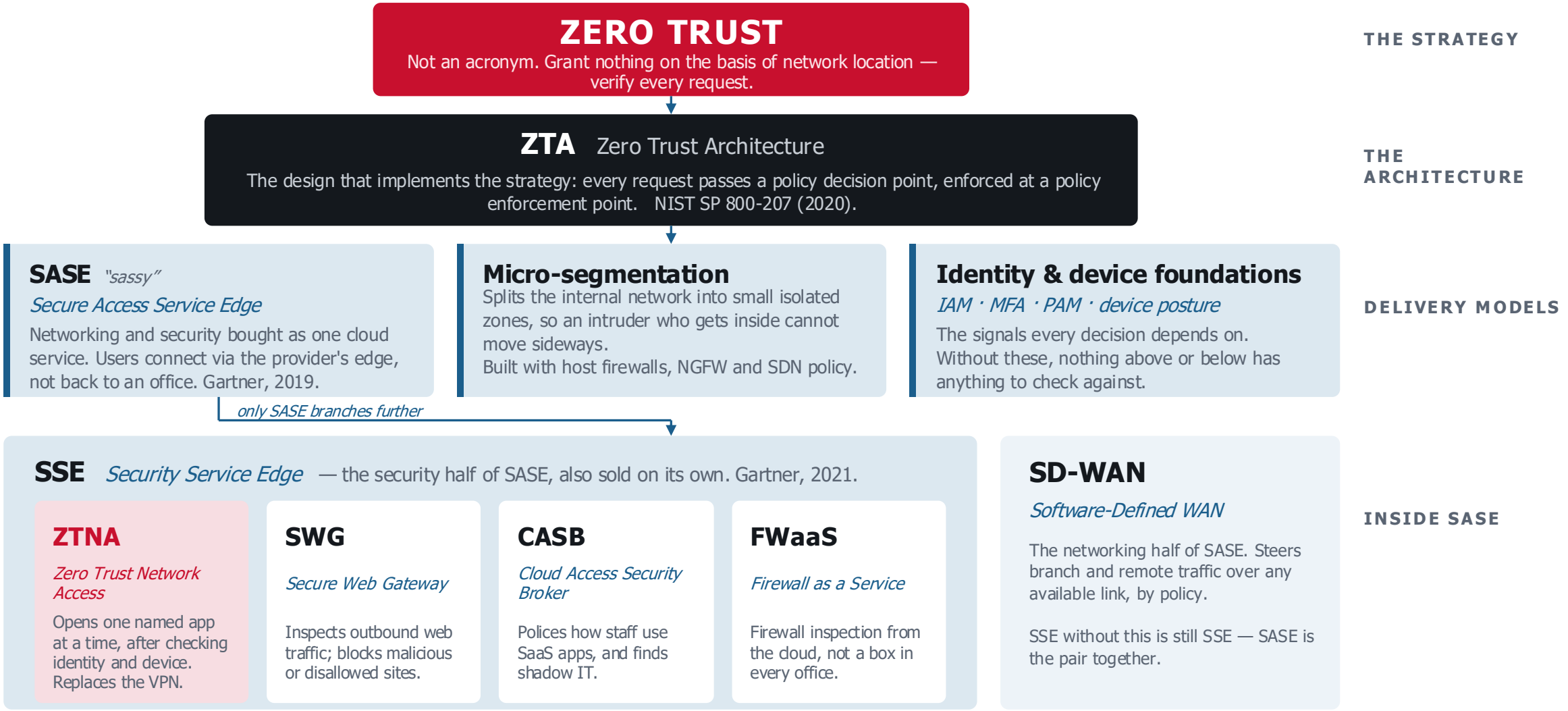
None of this is theoretical: sandboxes, approved-tool lists and network restrictions are ordinary practice.
What is new is applying them to agents.

FUTURE LIMITATIONS

	FIXED BY THE WORK IN PREVIOUS SLIDES	STILL OPEN
1	Knowing whose agent did what	Whether the action still matches what the person actually wanted
2	How much damage one compromised agent can do	Feeding an agent misleading information: a specific trick can be blocked, the technique cannot
3	The value of a stolen credential	An agent cannot reliably tell instructions from information it was given
4	Being able to prove what happened afterwards	Approval fatigue, wherever a human is still the safeguard
5	Permissions that are wider than they need to be	Whether an unpredictable actor can be given permissions safely at all


CONTEXT
CHALLENGES
FUTURE
TAKE AWAY

TAKE AWAY — THE BIG PICTURE



SASE = SSE + SD-WAN **SSE = ZTNA + SWG + CASB + FWaaS**

Watch out: ZTNA is Network **Access**, the architecture is ZTA, two tiers up. And nothing below the top two tiers *is* Zero Trust; they are products that help you implement it.

TAKE AWAY WORK IN PROGRESS

Zero Trust needs a way to describe an agent as a subject it can reason about.
That specification does not exist yet, this is the work in progress.

5 Feb 2026

NIST publishes a draft concept paper
On identity and permissions for AI agents, asking the industry what the requirements even are. Comments closed 2 April 2026.

17 Feb 2026

NIST launches an AI Agent Standards Initiative

Meetings and gap analyses, to inform standards that have not been written yet

27 Aug 2026

NIST staff publish on agent identity
The public comment thread has practitioners openly disagreeing on whether identity is even the right starting point

ongoing

FIDO Alliance work on credentials for agents

Tied to the user they act for, still at an early stage

TAKE AWAY STOP ASKING IF YOU ARE "ZERO TRUST"

Start asking whether an agent should be doing this at all.
and where in your architecture that question could even be answered.

1

Count them

List the agents and automated accounts you already have. Most organisations cannot name theirs.

2

Fix the basics first

Check your existing access management before adding agents. They multiply the gaps you already have.

3

Stop sharing logins

Give each agent its own identity, tied to its operator. This is what unlocks everything else.

4

Limit and time-box access

Rather than relying on approval prompts. Treat human approval as a control that wears out.

5

Decide who is accountable

For something an agent chose to do rather than a person asking for it, before you need the answer.

Four of these five are ordinary access-management hygiene, not AI work.
Most of the preparation is work you already know how to do.

TAKE AWAY SOURCES AND FURTHER READING

STANDARDS AND GUIDANCE

- NIST SP 800-207 — Zero Trust Architecture (2020)
- NIST SP 1800-35 — Implementing a ZTA (final, 10 Jun 2025)
- NIST IR 8587 — Protecting Tokens and Assertions from Forgery, Theft, and Misuse (final, 15 Sep 2026)
- NIST concept paper — AI agent identity and authorization (5 Feb 2026)
- NIST AI Agent Standards Initiative (17 Feb 2026)
- NIST Cybersecurity Insights — Back to the Future (27 Aug 2026)

SPECIFICATIONS

- RFC 6749 — OAuth 2.0
- RFC 9449 — DPoP
- RFC 9396 — Rich Authorization Requests
- SPIFFE / SPIRE · Transaction Tokens (draft)
- AuthZen — OpenID Foundation

THANK YOU! Any Questions?



ABOUT ELYSIUMSECURITY LTD.

ELYSIUMSECURITY PROVIDES A PORTFOLIO OF **STRATEGIC** AND **TACTICAL SERVICES** TO HELP COMPANIES **PROTECT** AND **RESPOND** AGAINST **CYBER SECURITY THREATS**. WE DIFFERENTIATE OURSELVES BY OFFERING **DISCREET**, **TAILORED** AND **SPECIALIZED** ENGAGEMENTS.

ELYSIUMSECURITY OPERATES IN **MAURITIUS** AND IN **EUROPE**, A ***BOUTIQUE STYLE*** APPROACH MEANS WE CAN **EASILY ADAPT** TO YOUR BUSINESS OPERATIONAL MODEL AND REQUIREMENTS TO PROVIDE A **PERSONALIZED SERVICE** THAT FITS YOUR WORKING ENVIRONMENT.

ELYSIUMSECURITY PROVIDES **HIGH LEVEL EXPERTISE** GATHERED THROUGH YEARS OF **BEST PRACTICES EXPERIENCE** IN LARGE INTERNATIONAL COMPANIES ALLOWING US TO PROVIDE ADVICE BEST SUITED TO YOUR **BUSINESS OPERATIONAL MODEL** AND **PRIORITIES**.

ELYSIUMSECURITY PROVIDES **PRACTICAL EXPERTISE** TO **IDENTIFY VULNERABILITIES**, ASSESS THEIR **RISKS** AND **IMPACT**, **REMEDIATE** THOSE RISKS, **PREPARE** AND **RESPOND** TO INCIDENTS AS WELL AS RAISE **SECURITY AWARENESS** THROUGH AN ORGANIZATION.

